ADMINISTRATION · EVERYONE

1 · Sign-in, roles and access

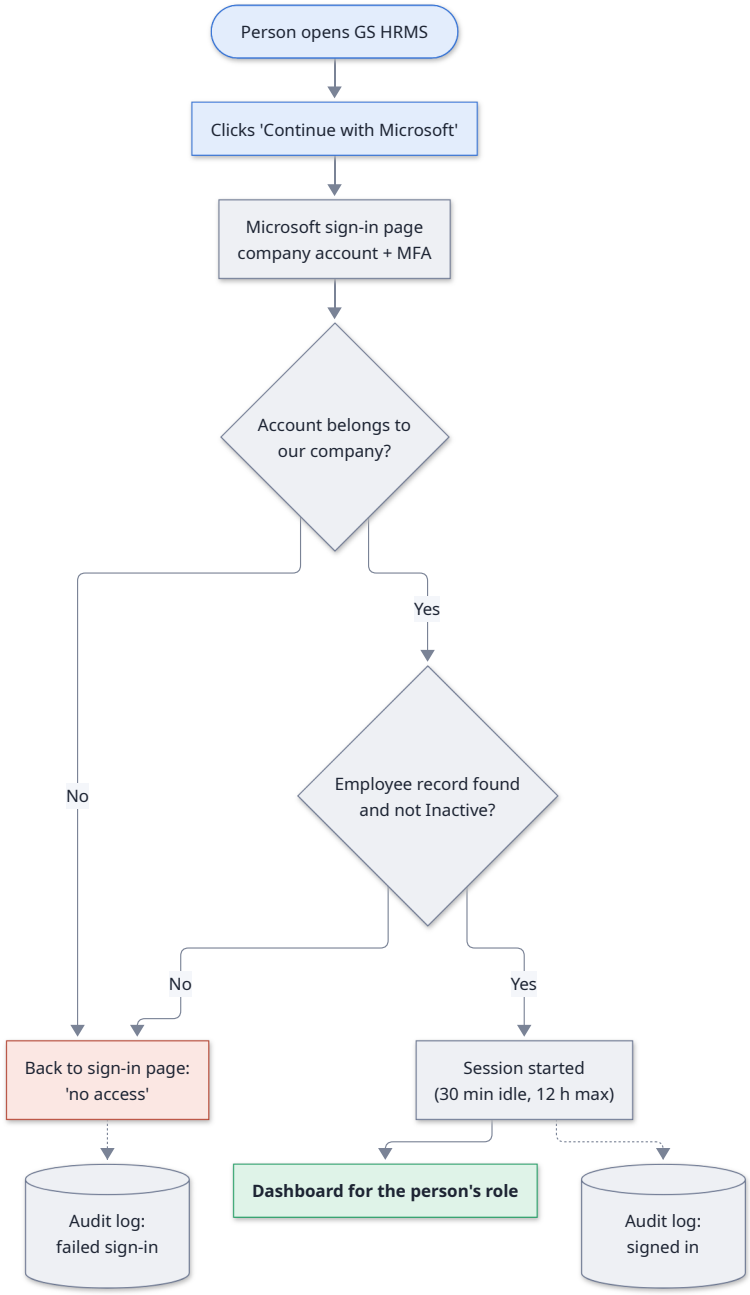
Who can get into the system, and what each person is allowed to see and do once inside.

Used by	Everyone Super Admin manages roles
Frontend	`/login` , `/admin/roles` , `lib/auth.ts` , `lib/access.ts` , `lib/guard.ts` , `lib/nav.ts`
Backend	Phase 0 — sign-in, sessions and the access check are built; Roles & Permissions API is next

In short

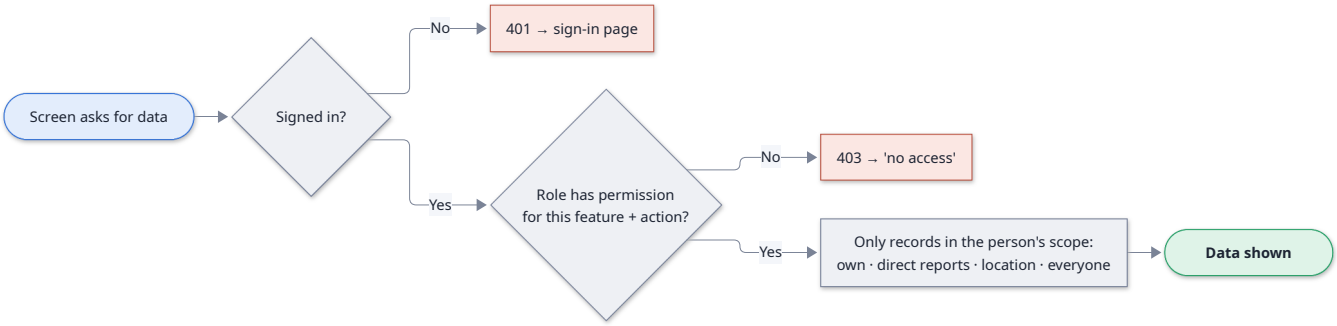
1. Everyone signs in with their **Microsoft 365** work account (with MFA). There are no separate HRMS passwords.
2. Each person has one **role**: Employee, Team Lead, HR, Office Admin or Super Admin.
3. The role decides which **screens** appear and which **actions** (view, add, edit, delete) are allowed.
4. Data is limited to the person's **scope**: own records, direct reports, their location, or everyone.

Signing in



1. Everyone signs in with their **Microsoft 365 work account**. Microsoft checks the password and MFA; GS HRMS never stores passwords.
2. The system looks for the employee record that belongs to that Microsoft account. On the very first sign-in it links them by work email.
3. People who are **Inactive** (left the company) or not in the system cannot get in.
4. The session ends after **30 minutes without activity**, after **12 hours** in total, on sign-out, or immediately when the employee is offboarded.
5. Every sign-in, sign-out and failed attempt is written to the audit log.

Every request is checked



Roles, spaces and permissions

Role	My Space	Team	Organization	Operations / Reports / Admin	Data scope
Employee	✔				Own records
Team Lead	✔	✔			Own + direct reports
HR	✔		✔	✔ (no delete in Administration)	All locations
Office Admin	✔		✔	✔ (never delete)	Own location
Super Admin	✔	✔	✔	✔	Everything

- Permissions are set per **feature** with four actions: **View, Add, Edit, Delete**. Add/Edit/Delete always need View.
- Features are grouped Module → Category → Feature (for example *Administration* → *Organization* → *Companies*).
- Super Admin can create **custom roles**, tick permissions per feature, and add custom features. System roles cannot be renamed.
- "Team" means **direct reports only**, not the whole tree below a manager.

Not in the frontend yet

- Sign-in only checks that the email exists — no password, no Microsoft. The persona switcher changes role freely.
- The permission matrix is shown but never enforced; custom roles disappear on page refresh and cannot be given to anyone.
- The backend now enforces all of this on every request. Next: the Roles & Permissions API and assigning roles to employees.